



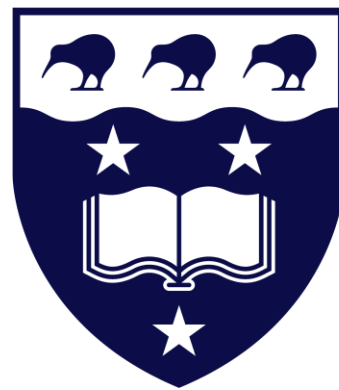
Lessons from a Real World Campaign using Web Apps

Kade Morton
Co-Founder, Arachne Digital

Thank You to Our Sponsors and Hosts!



OWASP
**NEW
ZEALAND**
owasp.org.nz



Waipapa
Taumata Rau
**University
of Auckland**



BASTION

SECURITY GROUP



**SECURE
CODE
WARRIOR**



plexure



Without them, this conference couldn't happen.

Contents

We will cover

- Iran 1940's to now
- Espionage against the diaspora
- Combatting espionage

A bit about me

Kade Morton

- Working in cybersecurity for 8 years
- Run threat intelligence firm Arachne Digital
- Interest in geopolitics



Iran 1940's to Now





<https://apnews.com/article/072580b5f24b4f8ea2402221d530257e>

The Shah of Iran (1941-1979)

Mohammad Reza Shah Pahlavi ruled with strong U.S. and Western support. Repression of political opposition (via secret police SAVAK) and deep inequality fuelled resentment.



https://en.wikipedia.org/wiki/File:Firing_Squad_in_Iran.jpg

The Iranian Revolution (1979)

Broad coalition of clerics, students, workers, and secular groups overthrew the Shah. Led by Ayatollah Ruhollah Khomeini, who returned from exile to establish the Islamic Republic. Clerical leadership eliminated rivals through arrests, executions, and exile.

Who are the IRGC?



After the revolution it was feared the armed forces would stage a coup, so an alternative paramilitary force was created, the Islamic Revolutionary Guard Corps (IRGC).

The IRGC has been characterised as a state within a state. It is estimated that one-third of the Iranian economy is controlled by the IRGC and its leaders.

Their remit is protection of the revolution.

The IRGC is considered a terrorist organisation by countries such as Canada and the United States. The New Zealand Government has explicitly said they are not considering designating the IRGC as a terrorist entity.

<https://www.britannica.com/topic/Islamic-Revolutionary-Guard-Corps>

Breaking
news!



Iran orchestrating violence in Australia

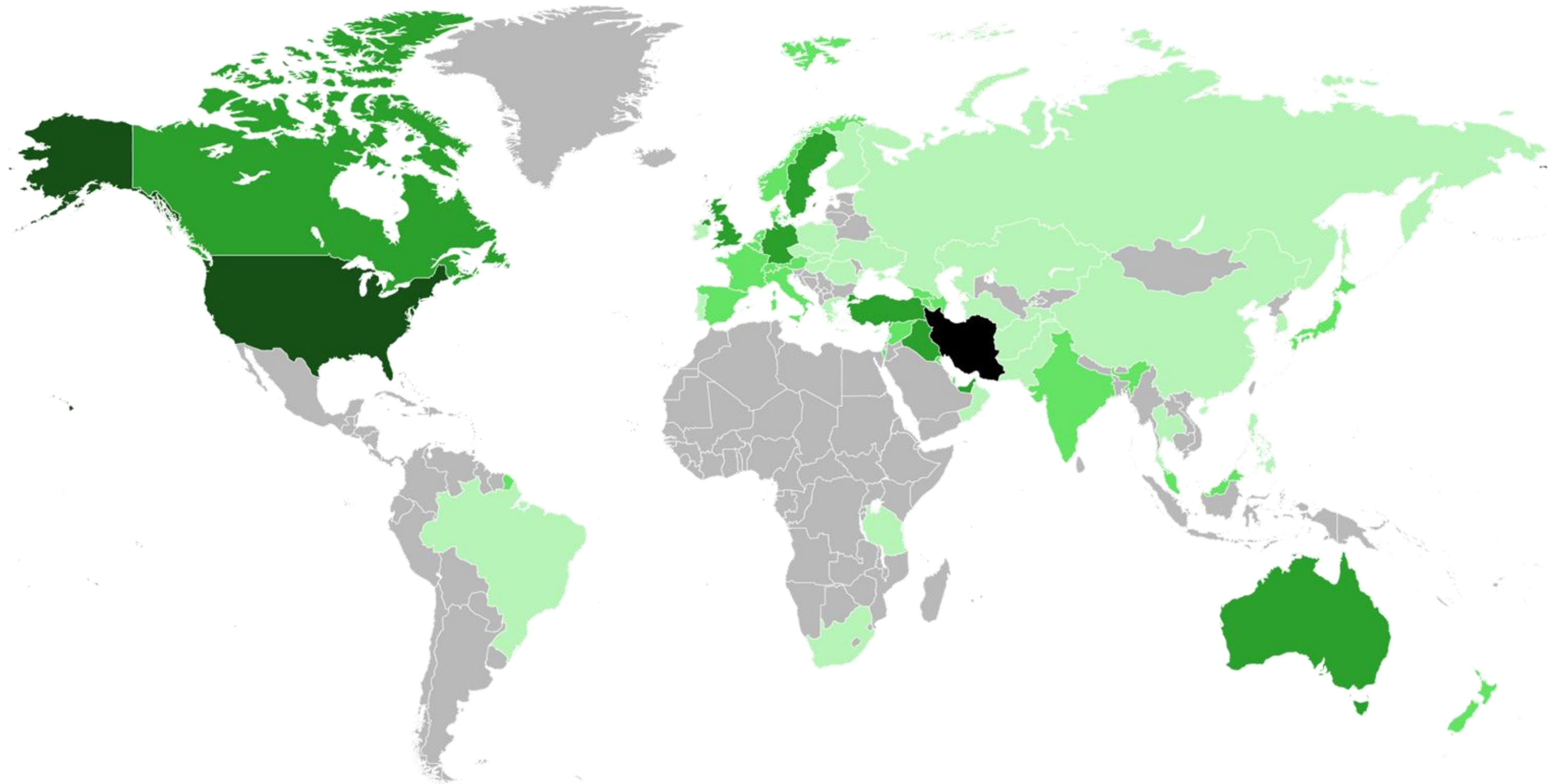


In 2024, a kosher deli in Sydney and a synagogue in Melbourne were firebombed.

On the 26th of August 2025, Australia claimed the IRGC had orchestrated the attacks.

Australia expelled the Iranian ambassador, the first ambassador Australia has expelled since World War II.

Australia is moving to designate the IRGC as a terrorist organisation.



https://en.wikipedia.org/wiki/Iranian_diaspora#/media/File:Map_of_the_Iranian_Diaspora_in_the_World.svg/2

Diaspora and dissidents abroad

Large Iranian exile populations in Germany, France, the U.S., and Canada became centers of opposition. Dissidents include journalists, activists, students, and ethnic minority advocates.

Why does the Iranian government care about the diaspora?



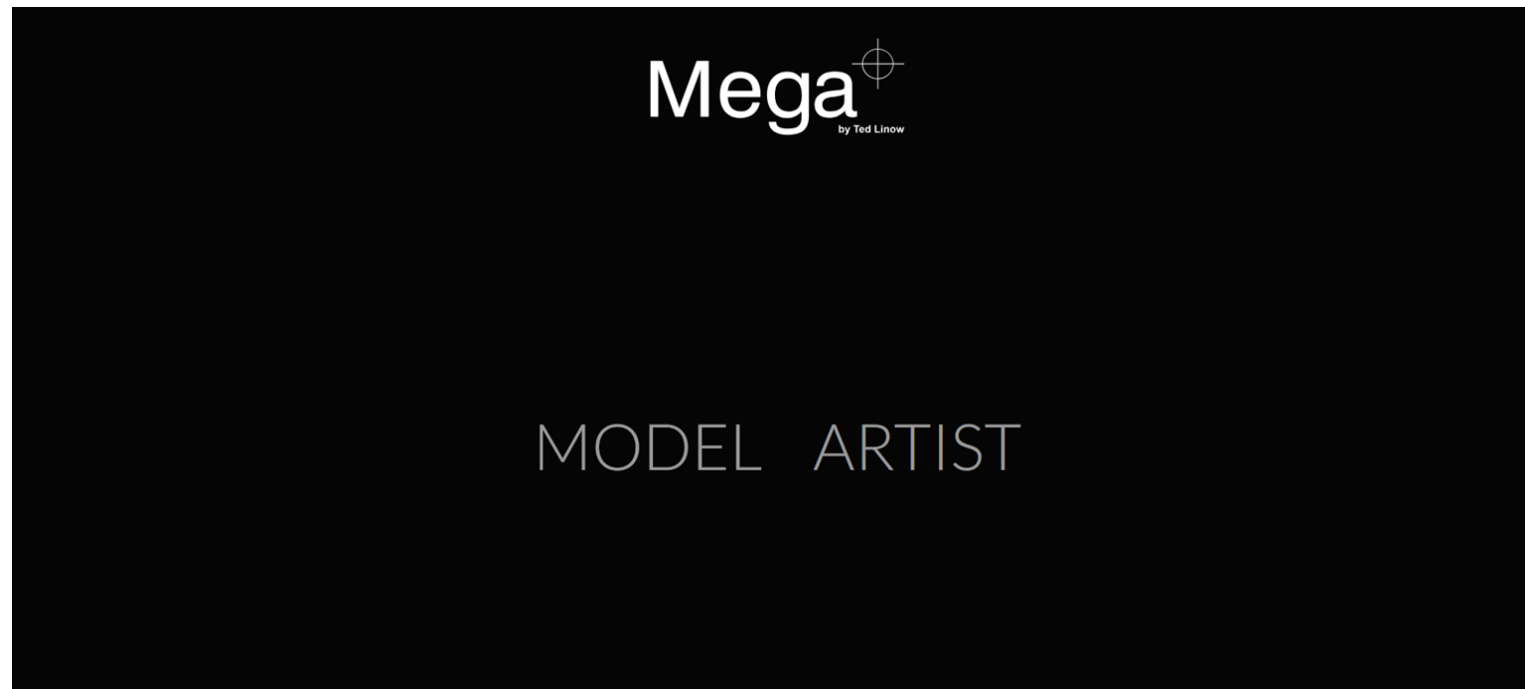
- This photo is of Ruhollah Khomeini, the person who deposed the Shah of Iran, giving a press conference before the revolution in front of his house in France.
- The current Iranian government understands very well that the diaspora can plot to overthrow you.

They did it.

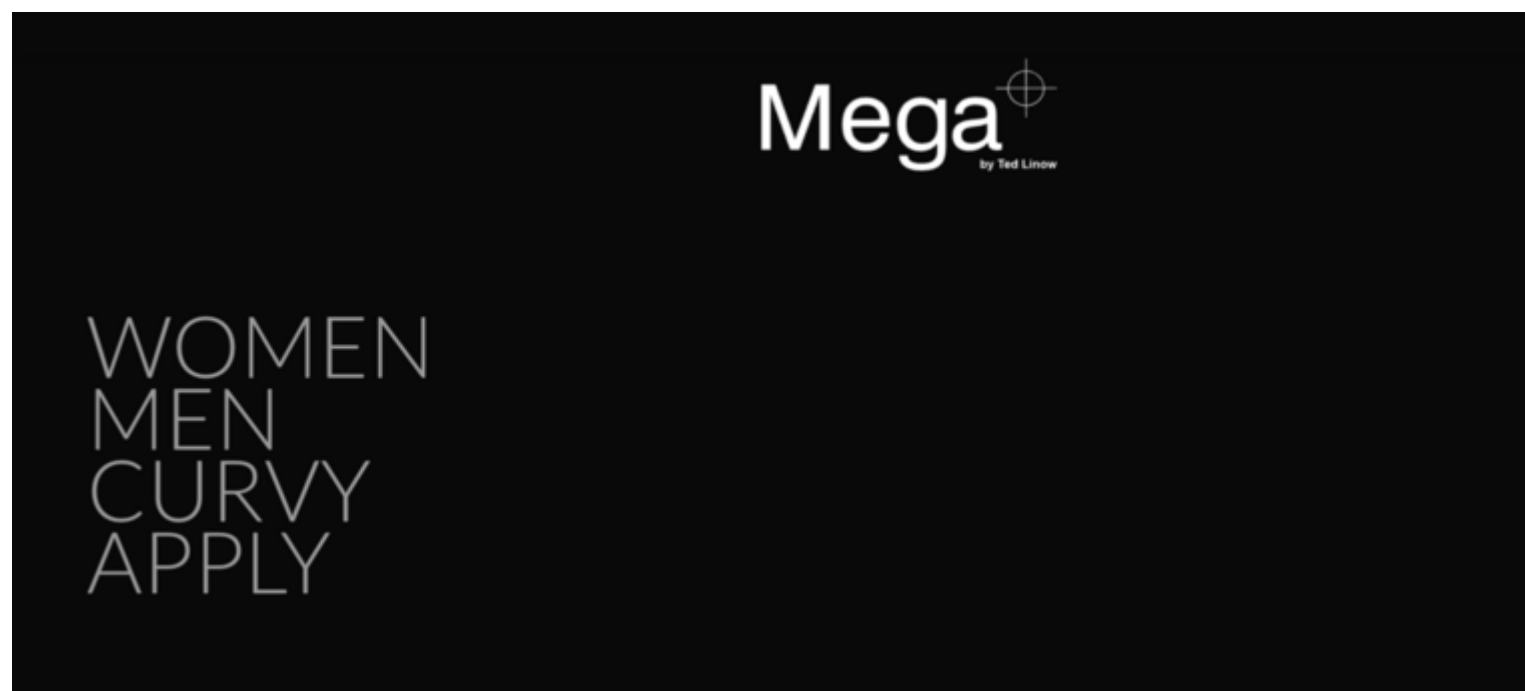
Espionage against the diaspora



A fake website



<https://www.megamodelagency.com/> real site



[megamodelstudio\[.\]com](https://megamodelstudio[.]com) fake site

Unit 42 found a fake website pretending to be Mega Model Agency, a modelling agency in Germany.

The fake website would check the details of the person viewing the site, and if the details matched set criteria it would replace one of the model profiles with a fake model.

The fake website was attributed with high confidence to Iranian cyber threat actors, with lower confidence to specifically a group that “overlapped” with APT35.

APT35 is attributed to the IRGC.

Technical details of the espionage

Registered on February 18, 2025, and hosted at IP address 64.72.205[.]32 since March 1, 2025. It:

- **Obfuscated JavaScript Executed**

Runs automatically when a visitor arrives.

- **Data Harvested for Browser Fingerprint**

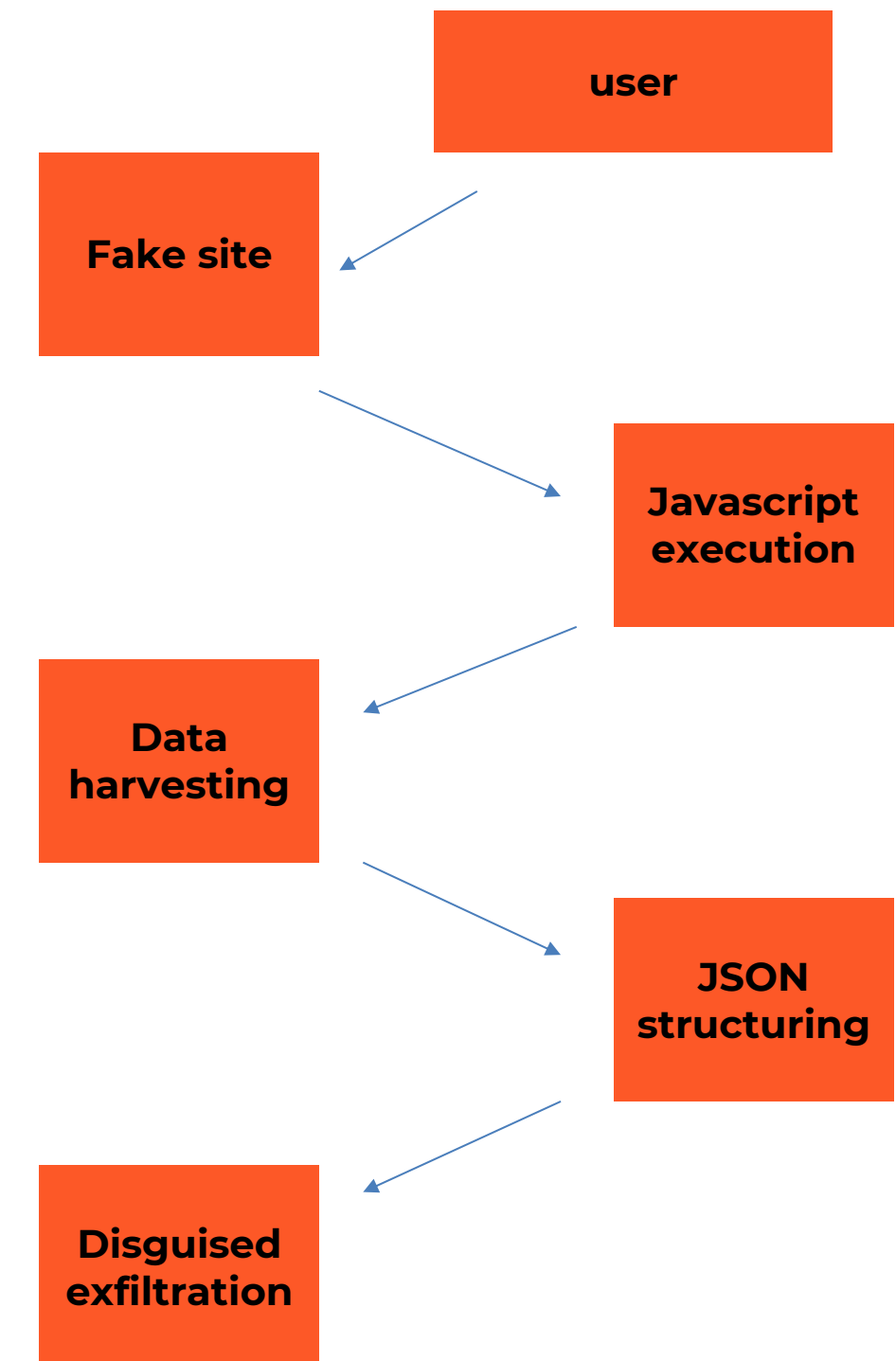
- Browser languages & plugins
- Screen resolution & timestamps
- Local & public IPs (via WebRTC leak)

- **Data Packaging**

Collected info structured in JSON format.

- **Exfiltration**

Sent via POST requests to /ads/track, disguised as ad-tracking traffic.



How does your IP leak?

- **WebRTC Basics**

WebRTC (Web Real-Time Communication) is an API built into most browsers to support video calls and peer-to-peer connections without needing plugins.

The protocol that WebRTC uses is ICE (Interactive Connectivity Establishment)

- **ICE Candidates**

When establishing a connection, the browser gathers “ICE candidates” — network routes including local (private) and public (WAN) IP addresses.

- **JavaScript Access**

Malicious JavaScript can call the WebRTC API (via a `RTCPeerConnection` object) to retrieve these candidates without user consent.

- **Information Leaked**

Local IP address (e.g., 192.168.x.x) — reveals device’s internal network setup.

- **Public IP address (e.g., ISP-assigned WAN IP)**

reveals geographical location and sometimes organization.

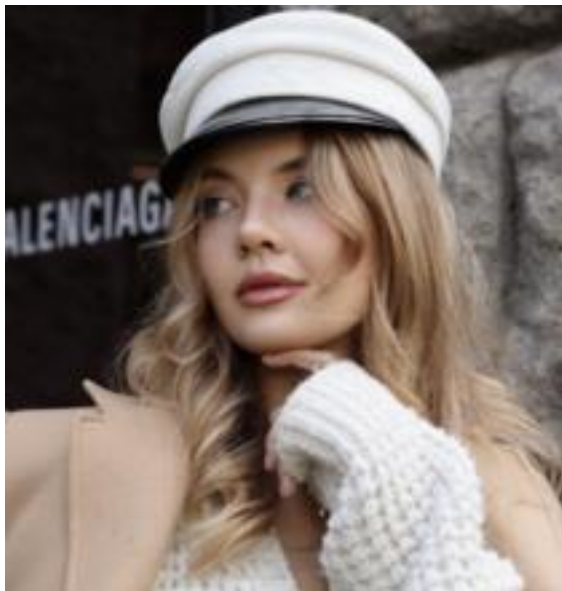
Can a browser fingerprint identify you?

Yes.

**You can be
identified from a
browser fingerprint**

- Research on WebAssembly-Based Fingerprinting from May of this year shows that that technique of browser fingerprinting has a false positive rate of less than 1%
<https://arxiv.org/abs/2506.00719>
- Research into behaviour based fingerprinting connected a user across sessions for an average of 51 days, and for some users up to 81 days, even with fingerprint drift <https://petsymposium.org/popets/2025/popets-2025-0158.pdf>
- The EFF's Panopticklick study (2010) found 83.6% of browser fingerprints were instantly unique; with Flash or Java, uniqueness rose to 94.2%
<https://coveryourtracks.eff.org/static/browser-uniqueness.pdf>

How does someone find themselves on this fake site?



- The attackers likely identified targets of interest and tailored outreach (e.g., via spear phishing) to lure them in.
- Once on the fake page, the attackers gathered technical information about the user's device
- From there the model's profile builds a level of trust that the person is real, and communication could continue on other platforms.



<https://unit42.paloaltonetworks.com/iranian-attackers-impersonate-model-agency/>

What can their info be used for?

1. Identify visitors from the Iranian diaspora, especially activists, journalists, or opposition figures.
2. Use device/browser fingerprints to allowlist interesting targets (e.g., specific regions, languages, ISPs).
3. Profiling diaspora communities helps Iran's intelligence services map opposition abroad.

Combating espionage



Tactics, techniques, and procedures

- T1016 **System Network Configuration Discovery**
- T1059.007 **Command and Scripting Interpreter: JavaScript**
- T1189 **Drive-by Compromise**
- T1217 **Browser Information Discovery**
- T1583.001 **Acquire Infrastructure: Domains**
- T1656 **Impersonation**

Mitigations

- **M1042 Disable or Remove Feature or Program**

Turn off or restrict access to unneeded scripting components.

- **M1021 Restrict Web-Based Content**

Script blocking extensions can help prevent the execution of JavaScript and HTA files that may commonly be used during the exploitation process. For malicious code served up through ads, adblockers can help prevent that code from executing in the first place.

- **M1051 Update Software**

Ensuring that all browsers and plugins are kept updated can help prevent the exploit phase of this technique. Use modern browsers with security features turned on.

- **M1017 User Training**

Train users to be aware of access or manipulation attempts by an adversary to reduce the risk of successful spearphishing, social engineering, and other techniques that involve user interaction.

- **M1019 Threat Intelligence Program**

Threat intelligence helps defenders and users be aware of and defend against common lures and active campaigns that have been used for impersonation.

Bibliography

- <https://unit42.paloaltonetworks.com/iranian-attackers-impersonate-model-agency/>
- <https://gbhackers.com/iranian-hackers-posing-as-model-agency/>
- https://nsiteam.com/social/wp-content/uploads/2020/12/NSI-ViTtA_IRGC-Black-Econ_CENTCOM-Q2_final-for-posting.pdf
- <https://www.aljazeera.com/news/2010/4/22/the-birth-of-a-new-class>
- <https://www.dpmc.govt.nz/sites/default/files/2024-07/pr-cab-24-sub-0202-govt-resp-focus-iran.pdf>
- <https://www.wired.com/story/browser-fingerprinting-tracking-explained/>
- <https://arxiv.org/abs/2506.00719>
- <https://petsymposium.org/popets/2025/popets-2025-0158.pdf>
- <https://attack.mitre.org/techniques/T1059/007/>
- <https://attack.mitre.org/techniques/T1016/>
- <https://attack.mitre.org/techniques/T1189/>
- <https://attack.mitre.org/techniques/T1217/>
- <https://attack.mitre.org/techniques/T1583/001/>
- <https://attack.mitre.org/techniques/T1656/>
- <https://www.aljazeera.com/news/2025/8/26/australia-accuses-iran-of-directing-antisemitic-attacks-expels-envoy>
- <https://www.abc.net.au/news/2025-08-26/iran-irgc-antisemitism-attacks-in-australia-explained/105699722>



Reach Out

Don't hesitate to contact us if you have any questions

Email contact@arachne.digital